

Business Associate / Subcontractor Agreement

Draft for legal and organizational review. Complete all blanks and UNSET rates before execution. This copy is unsigned; printing or previewing does not activate billing.

Effective date: _____. This agreement is between **MH4Kidz** (“MH4Kidz” or “Operator”), address _____, and **Plot Twist Co** (“Platform Provider”), address _____. SchoolCareBridge is a program identity operated by MH4Kidz, not a separate contracting legal entity.

1. Roles, scope and definitions

For covered information under this BAA, MH4Kidz acts as a Business Associate of the upstream Covered Entity or Entities identified below, and Platform Provider acts as its Subcontractor Business Associate. Upstream entities and applicable services/data scope: _____. The parties must complete and verify this scope before PHI is handled. Role labels do not establish that an entity actually satisfies a statutory definition.

“HIPAA Rules” means applicable provisions of 45 CFR Parts 160 and 164, as amended. Protected Health Information (PHI), Breach, Unsecured PHI, Security Incident, Designated Record Set, Individual, Secretary and Required by Law have their HIPAA meanings. PHI here means information created, received, maintained or transmitted by Platform Provider on behalf of MH4Kidz under the platform services, including electronic PHI. Information excluded from PHI by law, including certain FERPA education records, remains subject to applicable confidentiality and school agreements but is not converted into PHI by this BAA.

2. Permitted use and disclosure

Platform Provider may use or disclose PHI only as necessary to host, maintain, secure, support and transmit authorized records for the contracted services; as MH4Kidz lawfully directs within the scope of this BAA; or as Required by Law. It shall not use or disclose PHI in a manner that would violate the HIPAA Privacy Rule if done by the upstream Covered Entity. Access, requests, uses and disclosures must be limited to the minimum necessary where that standard applies. No sale, independent marketing, unrelated data aggregation, or general-purpose model training is permitted. De-identification or secondary use requires separate written instructions and lawful authority.

3. Safeguards and Security Rule

Platform Provider shall implement appropriate administrative, physical and technical safeguards to prevent unauthorized use or disclosure and comply with Subpart C of 45 CFR Part 164 for electronic PHI. It shall maintain risk analysis and risk management, workforce access controls, appropriate training, incident response, contingency procedures and audit controls suitable to its role. Workforce access must be limited to authorized persons bound to confidentiality. No mockup, public statement or product label is a certification of compliance.

4. Incident and breach reporting

Platform Provider shall report to MH4Kidz any use or disclosure not permitted by this BAA, Breach of Unsecured PHI, and Security Incident of which it becomes aware. Initial notice of suspected unauthorized access, material incident or breach is due without unreasonable delay and no later than 72 hours after discovery; the initial report may be incomplete. Notice of a Breach must satisfy 45 CFR 164.410 without unreasonable delay and in all events no later than its statutory 60-calendar-day outer limit. Discovery includes what would have been known through reasonable diligence by workforce members or agents other than the perpetrator.

Reports shall identify affected individuals and information to the extent known, discovery and incident dates, nature of the incident, containment, mitigation, corrective action and a response contact. Updates will follow promptly as facts become available. Platform Provider will preserve relevant evidence, reasonably cooperate in investigation and mitigate harmful effects to the extent practicable. MH4Kidz will promptly coordinate upstream notifications. Neither party may delay legally required notices while awaiting agreement on fault. This BAA does not delegate individual, regulator or media notices to Platform Provider without a separate written instruction consistent with law. Routine unsuccessful attacks with no unauthorized access or interference may be reported in an agreed periodic summary; material or successful incidents retain the prompt reporting duty.

5. Subcontractors

Before allowing a subcontractor to create, receive, maintain or transmit PHI on its behalf, Platform Provider shall obtain a written agreement imposing the same applicable restrictions, conditions and Security Rule requirements required of Platform Provider, consistent with 45 CFR 164.502(e) and 164.308(b). Platform Provider remains responsible for managing its subcontractors' performance and shall address known material violations, including termination where feasible if cure is unsuccessful.

6. Individual rights and delegated duties

Within ten business days of MH4Kidz's request, or sooner when necessary to permit an applicable legal deadline, Platform Provider shall make PHI in a Designated Record Set available to MH4Kidz in an available requested form and format for access under 45 CFR 164.524; make or incorporate directed

amendments under 164.526; and supply information needed for an accounting of disclosures under 164.528. It shall maintain the necessary disclosure information. Direct individual requests shall be forwarded to MH4Kidz within three business days; Platform Provider will not independently deny a request. Any delegated Covered Entity Privacy Rule obligation shall be performed in accordance with the requirements applicable to that obligation.

7. Oversight and Operator responsibilities

Platform Provider shall make its relevant internal practices, books and records available to the Secretary for determining compliance with the HIPAA Rules. MH4Kidz shall provide applicable notice-of-privacy-practices limits, agreed restrictions, changes or revocations of permissions, and upstream contractual requirements affecting these services. MH4Kidz shall not request an impermissible use or disclosure and shall maintain required upstream authority. Reasonable compliance information shall be exchanged without exposing other customers' protected information.

8. Term and termination for cause

This BAA becomes effective when both parties sign and continues while Platform Provider maintains covered PHI. MH4Kidz may terminate the underlying service arrangement if Platform Provider materially violates this BAA and fails to cure within a reasonable period specified in written notice, or immediately if cure is not possible. The parties shall stop impermissible processing promptly; this does not excuse necessary safeguarding or reporting.

9. Return, destruction and survival

At termination, Platform Provider shall return or destroy all PHI received from MH4Kidz or created or maintained on its behalf, including subcontractor copies, where feasible. Within 30 days the parties will agree the secure export and deletion process. If return or destruction is infeasible, Platform Provider shall notify MH4Kidz in writing of the specific reasons, retain only the information necessary for that purpose, extend this BAA's protections to retained PHI and limit further use/disclosure to the purpose making return/destruction infeasible. Protected backups remain safeguarded until their documented deletion cycle. These obligations survive termination. PHI may not be withheld solely to collect a disputed commercial fee.

10. Construction and notices

This BAA controls any conflicting commercial term concerning PHI. It does not waive either party's direct legal obligations or authorize access beyond existing roles, consent and scope. Amendments necessary to comply with applicable law will be made promptly in writing. No third-party beneficiary right is created except as required by law. Security/privacy notice contacts: MH4Kidz

_____; Platform Provider _____.

Each party must keep its contacts current.

Signatures

Each signer represents that they are authorized to bind the named legal entity. Counterparts and valid electronic signatures are permitted. Neither an unsigned draft nor an app setting constitutes a signature.

MH4Kidz

Signature: _____

Printed name and title: _____

Date: _____

Plot Twist Co

Signature: _____

Printed name and title: _____

Date: _____